

# Splunk SIEM Home Lab

Lalith Vardhan Boddala

June 2026

**Status:** COMPLETE

**Links:** [LinkedIn Profile](#)

---

## Executive Summary

This project demonstrates the end-to-end engineering, configuration, and operationalization of a locally hosted Security Information and Event Management (SIEM) environment. The primary objective was to simulate real-world adversarial techniques, specifically Network Service Discovery and SMB Brute Force attacks, and develop high-fidelity detection rules within Splunk. By routing Windows endpoint telemetry via Sysmon and the Splunk Universal Forwarder, this lab establishes a functional threat detection pipeline that mirrors enterprise SOC operations.

## Skills Demonstrated

- **SIEM Engineering & Administration:** Splunk Enterprise setup, Universal Forwarder deployment, and log pipeline troubleshooting.
- **Endpoint Detection & Response (EDR) Telemetry:** Deployment and tuning of Sysmon utilizing SwiftOnSecurity configurations to capture high-value forensic artifacts.
- **Detection Engineering (SPL):** Writing, testing, and refining Splunk Search Processing Language (SPL) queries to detect specific malicious behaviors with low false-positive rates.
- **Threat Hunting & Incident Investigation:** Analyzing Event IDs (EIDs 3, 4625, 4740) to construct attack timelines and attribute adversarial activity.
- **Framework Alignment:** Mapping attacks and detections to the MITRE ATT&CK® framework.
- **Systems Administration:** Linux administration for offensive operations and Python scripting logic for automated analytical workflows.

## Lab Architecture Overview

The environment was constructed locally using virtualized networking, ensuring isolated execution and realistic telemetry generation without relying on abstracted cloud logging services.

| Component       | Host / OS       | Role & Configuration                                                        | Network Alias  |
|-----------------|-----------------|-----------------------------------------------------------------------------|----------------|
| SIEM Server     | MacBook Air M2  | Splunk Enterprise 10.4. Receives and indexes logs on TCP 9997.              | SIEM_SERVER    |
| Victim Endpoint | Windows 10 (VM) | Target machine. Runs Sysmon v15 and Splunk Universal Forwarder 10.4.        | WINDOWS_TARGET |
| Attack Node     | Kali Linux (VM) | Offensive infrastructure for staging Nmap and Metasploit framework modules. | KALI_ATTACKER  |

## Log Forwarding Pipeline

- **Telemetry Source:** Windows Event Logs and Sysmon Operational logs capture process creations, network connections, and file modifications.
- **Transport:** Splunk Universal Forwarder routes data to SIEM\_SERVER:9997 via `outputs.conf`.
- **Ingestion:** Data is parsed into the `main` index, generating over 6,500 distinct events during baseline and attack operations.

## Attack & Detection Scenarios

### Scenario 1: Network Service Discovery (Port Scanning)

#### Objective & Attack Description:

The adversary aims to map the target's attack surface to identify open ports and vulnerable services.

- **MITRE ATT&CK Technique:** T1046 - Network Service Discovery
- **Execution Method:** An aggressive TCP connect and SYN scan with OS fingerprinting was initiated from the Kali node using Nmap. (`nmap -sV -sC -O -p- WINDOWS_TARGET`)
- **Evidence Collected:** The scan successfully identified open ports 135 (RPC) and 445 (SMB).

#### Detection Logic & Investigation:

*Note: A common misconception is that inbound Nmap scans generate `PING.EXE` process creation events on the target. In reality, inbound network scans are captured as rapid network connection attempts.*

```
index=main source="*Sysmon/Operational*" EventCode=3
| stats dc(DestinationPort) as ports_scanned by SourceIp
| where ports_scanned > 10
| sort -ports_scanned
```

- **Detection Rationale:** Sysmon Event ID 3 (Network Connection) logs inbound connection requests. This SPL query calculates the distinct count (`dc`) of destination ports accessed by a single Source IP. A threshold of `>10` ports scanned from a single host within a short timeframe strongly indicates automated reconnaissance.

- **False Positives & Tuning:** Enterprise vulnerability scanners (e.g., Nessus, Qualys) will trigger this alert. The rule should be tuned to explicitly whitelist the IP addresses of authorized scanning subnets.
- **Analyst Assessment:** Immediate isolation is not required for a scan alone, but the offending IP should be added to a watchlist. Correlation with subsequent authentication attempts is critical.

## Scenario 2: SMB Brute Force & Password Guessing

### Objective & Attack Description:

Following the discovery of an open SMB service (Port 445), the adversary attempts to compromise the `administrator` account using a dictionary attack.

- **MITRE ATT&CK Technique:** T1110.001 - Password Guessing
- **Execution Method:** The Metasploit Framework's `smb_login` auxiliary module was utilized alongside the `rockyou.txt` wordlist. Metasploit natively handles SMBv2, overcoming standard connection resets common with older tools like Hydra.
- **Evidence Collected:** Metasploit console output recorded continuous authentication failures until triggering a remote account lockout.

### Detection Logic & Investigation:

```
index=main source="WinEventLog:Security" EventCode=4625
| stats count by Account_Name, host, Source_Network_Address
| where count > 5
| sort -count
```

- **Investigation Findings:** Splunk ingested a high volume of Event ID 4625 (Failed Logon). The data showed multiple failed attempts targeting the `administrator` account from a single source IP in milliseconds.
- **Detection Rationale:** Aggregating failed logins by `Account_Name` and identifying counts exceeding typical human error thresholds (e.g., >5) effectively isolates automated credential stuffing or brute force behavior.
- **False Positives & Tuning:** Users legitimately forgetting passwords will trigger Event 4625. To increase fidelity, the SPL should be enhanced utilizing `bin _time span=5m` to measure velocity (e.g., 5 failures *within 5 minutes*) rather than aggregate failures over a day.
- **Analyst Assessment:** This represents a high-severity alert. The SOC response dictates an immediate network block at the perimeter firewall for the offending Source IP.

## Scenario 3: Defensive Efficacy - Account Lockout

### Detection Logic & Investigation:

- **MITRE ATT&CK Technique:** T1110 - Brute Force

```
index=main source="WinEventLog:Security" EventCode=4740
| table _time, Account_Name, host
```

- **Investigation Findings:** At exactly 16:17:40, Windows Event ID 4740 (Account Lockout) was generated for the `administrator` account.
- **Analyst Assessment:** This confirms that the target system's local security policy operated correctly, halting the brute force progression. In a SOC environment, EID 4740 is a critical pivot point; analysts must immediately review the preceding 4625 events to determine if the lockout was caused by a malicious external brute force, a misconfigured internal service account, or user error.

## Technical Troubleshooting & Engineering Resilience

Building a raw SIEM pipeline requires significant platform engineering. The following issues were diagnosed and resolved during deployment:

| Failure State                             | Root Cause Analysis                                                                                             | Engineering Resolution                                                                                                          |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>Zero-byte .conf file corruption</b>    | PowerShell backtick new-lines and default encoding corrupted Splunk configuration files on Windows.             | Re-engineered deployment scripts to use <code>Out-File -Encoding ascii</code> to enforce strict ASCII compliance.               |
| <b>Sysmon logs blocked by permissions</b> | The default Splunk Forwarder service account lacked permissions to read Sysmon Operational logs.                | Migrated the Splunk Forwarder to the <code>Local System</code> account and flushed the Splunk fishbucket to force re-ingestion. |
| <b>Silent Log Pipeline Failure</b>        | DHCP IP reassignment on the macOS host broke the hardcoded target IP in the Windows <code>outputs.conf</code> . | Locked the SIEM server to a manual IP address allocation at the host networking level.                                          |

## Conclusion & Key Outcomes

This project successfully transitions theoretical security concepts into a tangible, functioning SOC pipeline. By engineering the environment from the ground up—without relying on pre-configured cloud ranges—I demonstrated hands-on capability in:

1. **Infrastructure Provisioning:** Successfully routing, parsing, and indexing over 6,500 end-point events.

2. **Adversarial Emulation:** Safely executing T1046 and T1110 attack vectors using industry-standard offensive tooling.
3. **Detection Engineering:** Translating raw machine data into actionable, high-fidelity security alerts tailored for SOC triage workflows.

The resulting analytics, troubleshooting methodology, and documentation prove a high degree of readiness for executing investigations, tuning SIEM rules, and responding to alerts within a professional Security Operations Center.